

CEHv13 MODULE 3 – SCANNING

NOTES BY VIVEK GOSWAMI

Scanning itself is not the actual intrusion, but an extended form of reconnaissance in which the ethical hacker and pen tester learns more about the target, including information about open ports and services, OS, and any configuration lapses. The information gleaned from this reconnaissance helps you to select strategies for the attack on the target system or network.

Learning Objectives

- Understand network protocol fundamentals (TCP/UDP, OSI/TCP-IP models)
- Master network discovery and host enumeration techniques
- Learn comprehensive port scanning methodologies
- Develop skills in service version detection and OS fingerprinting
- Understand firewall and IDS evasion techniques
- Explore advanced scanning tools and automation strategies
- Master Nmap Scripting Engine (NSE) for vulnerability detection
- Perform AI-based Scanning

Types of Scanning:

- - Port Scanning
 - Detects open, closed, or filtered ports on target systems.
 -
- - Service Scanning
 - Identifies services running on open ports to understand available network applications.
 -
- - Version Detection
 - Determines application or service versions to identify potential vulnerabilities.
 -
- - OS Fingerprinting
 - Detects the target operating system based on network behaviour and responses.
 -
- - Vulnerability Scanning
 - Matches detected services and versions to known vulnerabilities for risk assessment.

Network Protocol

Tcp vs Udp

TCP (Transmission Control Protocol) and UDP (User Datagram Protocol) are core transport layer protocols that define how data packets are transmitted across networks.

Characteristic	TCP	UDP
Connection Type	Connection-oriented protocol	Connectionless protocol
Reliability	Provides error checking and correction	No error checking mechanism
Data Delivery	Guarantees delivery of data	No guarantees of data delivery
Transmission Speed	Slower due to overhead	Faster transmission
Packet Routing	All packets follow the same path	Packets can follow any path
Retransmission	Automatic retransmission possible	No retransmission capability
Use Cases	Web browsing, email, file transfer	Streaming, gaming, DNS queries

TCP Control Flags:

- SYN (Synchronise): Initiates the three-way handshake between hosts to start a connection.
- ACK (Acknowledgement): Acknowledges successful receipt of packets.
- FIN (Finished): Indicates no more data will be sent; used to gracefully terminate a connection.
- RST (Reset): Immediately terminates a connection due to errors or unexpected conditions.
- PSH (Push): Forces the immediate processing of buffered data.
- URG (Urgent): Marks urgent data that should be processed right away.

TCP Three-Way Handshake:

1. SYN: Client sends a SYN flag to initiate connection, synchronizing sequence numbers.
2. SYN-ACK: Server responds with SYN and ACK flags set, acknowledging client's SYN and synchronizing its own sequence number.
3. ACK: Client sends an ACK flag to acknowledge server's SYN; the connection is then established.

This handshake establishes a reliable, full-duplex communication channel between client and server.

Network Models and Architecture

OSI (Open Systems Interconnection) Model

<u>Layer</u>	<u>Name</u>	<u>Description</u>	<u>Example Protocol</u>
7	Application	Human-computer interaction interface	HTTP, HTTPS, FTP, SMTP, DNS
6	Presentation	Data formatting, encryption, compression	TLS/SSL, JPEG, PNG, ASCII
5	Session	Session management and control	NetBIOS, RPC, SQL sessions
4	Transport	Reliable data transmission	TCP, UDP, SCTP
3	Networking	Routing and logical addressing	IP, ICMP, OSPF, BGP
2	Data Link	Node-to-node data transfer	Ethernet, Wi-Fi, ARP
1	Physical	Physical transmission medium	Cables, radio waves, Fiber optics

Methodology:

- Identify Live Hosts
Perform a ping sweep to find responsive systems on the network.
- Port Scanning
Scan the target for open ports and available services to identify potential entry points.
- Service Version Detection
Identify the exact software versions of running services for vulnerability assessment.
- OS Detection
Determine the target operating system to tailor exploit techniques.
- Vulnerability Mapping
Map discovered services and versions to known CVEs or vulnerabilities for attack planning.

Common Tools for Scanning:

- Nmap – Advanced port scanning, OS detection, and scripting capabilities.
- Masscan – High-speed port scanning tool suited for large networks.
- Netcat (nc) – Versatile tool for port scanning and banner grabbing.
- Zenmap – Graphical user interface (GUI) for Nmap, simplifying its usage.
- Unicornscan – Asynchronous TCP and UDP network scanning tool.
- Nessus / OpenVAS – Vulnerability scanning solutions that map services to known weaknesses.

Nmap Port States:

- - **Open:** Service actively listening and accepting connections.
- - **Closed:** Port accessible but no service listening.
- - **Filtered:** Packet filtered by firewall, no response received.
- - **Unfiltered:** Port accessible but unknown if open or closed.
- - **Open Filtered:** Cannot determine if open or filtered.
- - **Closed Filtered:** Cannot determine if closed or filtered.

Network Discovery Method

(Local Network) - ARP Based Discovery

ARP scanning for local subnet discovery

arp-scan --local # Scan local network segment

arp-scan 192.168.1.0/24 # Specific subnet ARP scan

arp-scan -I eth0 192.168.1.0/24 # Interface-specific scan

netdiscover -r 192.168.1.0/24 # Active network discovery

netdiscover -r 192.168.1.0/24 -P # Passive network discovery

ICMP-BASED Discovery

ICMP ping sweeps

nmap -sn 192.168.1.0/24 # No port scan ping sweep

nmap -sn -PE 192.168.1.0/24 # ICMP Echo ping

nmap -sn -PP 192.168.1.0/24 # ICMP Timestamp ping

nmap -sn -PM 192.168.1.0/24 # ICMP Address Mask ping

fping -a -g 192.168.1.0/24 # Fast ping alternative

Nmap Cheat Sheet

Target Specification

Switch	Example	Description
	<code>nmap 192.168.1.1</code>	Scan a single IP
	<code>nmap 192.168.1.1 192.168.2.1</code>	Scan specific IPs
	<code>nmap 192.168.1.1-254</code>	Scan a range
	<code>nmap scanme.nmap.org</code>	Scan a domain
	<code>nmap 192.168.1.0/24</code>	Scan using CIDR notation
<code>-iL</code>	<code>nmap -iL targets.txt</code>	Scan targets from a file
<code>-iR</code>	<code>nmap -iR 100</code>	Scan 100 random hosts
<code>--exclude</code>	<code>nmap --exclude 192.168.1.1</code>	Exclude listed hosts

Scan Techniques

Switch	Example	Description

-sS	nmap 192.168.1.1 -sS	TCP SYN port scan (Default)
-sT	nmap 192.168.1.1 -sT	TCP connect port scan (Default without root privilege)
-sU	nmap 192.168.1.1 -sU	UDP port scan
-sA	nmap 192.168.1.1 -sA	TCP ACK port scan
-sW	nmap 192.168.1.1 -sW	TCP Window port scan
-sM	nmap 192.168.1.1 -sM	TCP Maimon port scan

Host Discovery

Switch	Example	Description
-sL	nmap 192.168.1.1-3 -sL	No Scan. List targets only
-sn	nmap 192.168.1.1/24 -sn	Disable port scanning. Host discovery only.
-Pn	nmap 192.168.1.1-5 -Pn	Disable host discovery. Port scan only.

-PA	nmap 192.168.1.1-5 -PA22-25,80	TCP ACK discovery on port x.
Port 80 by default		
-PU	nmap 192.168.1.1-5 -PU53	UDP discovery on port x. Port 40125 by default
-PR	nmap 192.168.1.1-1/24 -PR	ARP discovery on local network
-n	nmap 192.168.1.1 -n	Never do DNS resolution

Port Specification

Switch	Example	Description
-p	nmap 192.168.1.1 -p 21	Port scan for port x
-p	nmap 192.168.1.1 -p 21-100	Port range
-p	nmap 192.168.1.1 -p U:53,T:21-25,80	Port scan multiple TCP and UDP ports
-p-	nmap 192.168.1.1 -p-	Port scan all ports
-p	nmap 192.168.1.1 -p http,https	Port scan from service name

-F	nmap 192.168.1.1 -F	Fast port scan (100 ports)
--top-ports	nmap 192.168.1.1 --top-ports 2000	Port scan the top x ports
-p-65535	nmap 192.168.1.1 -p-65535	Leaving off initial port in range makes the scan start at port 1
-p0-	nmap 192.168.1.1 -p0-	Leaving off end port in range makes the scan go through to port 65535

Service and Version Detection

Switch	Example	Description
-sV	nmap 192.168.1.1 -sV	Attempts to determine the version of the service running on port
-sV --version-intensity	nmap 192.168.1.1 -sV --version-intensity 8	Intensity level 0 to 9. Higher number increases possibility of correctness
-sV --version-light	nmap 192.168.1.1 -sV --version-light	Enable light mode. Lower possibility of correctness. Faster
-sV --version-all	nmap 192.168.1.1 -sV --version-all	Enable intensity level 9. Higher possibility of correctness. Slower

-A	nmap 192.168.1.1 -A	Enables OS detection, version detection, script scanning, and traceroute
-----------	----------------------------	---

OS Detection

Switch	Example	Description
-O	nmap 192.168.1.1 -O	Remote OS detection using TCP/IP stack fingerprinting
-O --osscan-limit	nmap 192.168.1.1 -O --osscan-limit	If at least one open and one closed TCP port are not found it will not try OS detection against host
-O --osscan-guess	nmap 192.168.1.1 -O --osscan-guess	Makes Nmap guess more aggressively
-O --max-os-tries	nmap 192.168.1.1 -O --max-os-tries 1	Set the maximum number x of OS detection tries against a target
-A	nmap 192.168.1.1 -A	Enables OS detection, version detection, script scanning, and traceroute

Timing and Performance

Switch	Example	Description
-T0	nmap 192.168.1.1 -T0	Paranoid (0) Intrusion Detection System evasion
-T1	nmap 192.168.1.1 -T1	Sneaky (1) Intrusion Detection System evasion
-T2	nmap 192.168.1.1 -T2	Polite (2) slows down the scan to use less bandwidth and use less target machine resources
-T3	nmap 192.168.1.1 -T3	Normal (3) which is default speed
-T4	nmap 192.168.1.1 -T4	Aggressive (4) speeds scans; assumes you are on a reasonably fast and reliable network
-T5	nmap 192.168.1.1 -T5	Insane (5) speeds scan; assumes you are on an extraordinarily fast network

Switch	Example input	Description
--host-timeout <time>	1s; 4m; 2h	Give up on target after this long
--min-rtt-timeout/max-rtt-timeout/initial-rtt-timeout <time>	1s; 4m; 2h	Specifies probe round trip time
--min-hostgroup/max-hostgroup <size>	50; 1024	Parallel host scan group sizes
--min-parallelism/max-parallelism <numprobes>	10; 1	Probe parallelization
--scan-delay/--max-scan-delay <time>	20ms; 2s; 4m; 5h	Adjust delay between probes
--max-retries <tries>	3	Specify the maximum number of port scan probe retransmissions
--min-rate <number>	100	Send packets no slower than <numberr> per second
--max-rate <number>	100	Send packets no faster than <number> per second

Switch	Example	Description
-sC	nmap 192.168.1.1 -sC	Scan with default NSE scripts. Considered useful for discovery and safe
--script default	nmap 192.168.1.1 --script default	Scan with default NSE scripts. Considered useful for discovery and safe
--script	nmap 192.168.1.1 --script=banner	Scan with a single script. Example banner
--script	nmap 192.168.1.1 --script=http*	Scan with a wildcard. Example http
--script	nmap 192.168.1.1 --script=http,banner	Scan with two scripts. Example http and banner
--script	nmap 192.168.1.1 --script "not intrusive"	Scan default, but remove intrusive scripts
--script-args	nmap --script snmp-sysdescr --script-args snmpcommunity=admin 192.168.1.1	NSE script with arguments

Useful NSE Script Examples

Command	Description
---------	-------------

nmap -Pn --script=http-sitemap-generator scanme.nmap.org	http site map generator
nmap -n -Pn -p 80 --open -sV -vvv --script banner,http-title -iR 1000	Fast search for random web servers
nmap -Pn --script=dns-brute domain.com	Brute forces DNS hostnames guessing subdomains
nmap -n -Pn -vv -O -sV --script smb-enum*,smb-ls,smb-mbenum,smb-os-disco very,smb-s*,smb-vuln*,smbv2* -vv 192.168.1.1	Safe SMB scripts to run
nmap --script whois* domain.com	Whois query
nmap -p80 --script http-unsafe-output-escaping scanme.nmap.org	Detect cross site scripting vulnerabilities
nmap -p80 --script http-sql-injection scanme.nmap.org	Check for SQL injections

Firewall / IDS Evasion and Spoofing

Switch	Example	Description

-f	nmap 192.168.1.1 -f	Requested scan (including ping scans) use tiny fragmented IP packets. Harder for packet filters
--mtu	nmap 192.168.1.1 --mtu 32	Set your own offset size
-D	nmap -D 192.168.1.101,192.168.1.102, 192.168.1.103,192.168.1.23 192.168.1.1	
Send scans from spoofed IPs		
-D	nmap -D decoy-ip1,decoy-ip2,your-own-ip,decoy-ip3,decoy-ip4 remote-host-ip	Above example explained
-S	nmap -S <u>www.microsoft.com</u> <u>www.facebook.com</u>	Scan Facebook from Microsoft (-e eth0 -Pn may

		be required)
-g	nmap -g 53 192.168.1.1	Use given source port number
--proxies	nmap --proxies <u>http://192.168.1.1:8080</u>, <u>http://192.168.1.2:8080</u> 192.168.1.1	Relay connections through HTTP/SOCKS4 proxies
--data-length	nmap --data-length 200 192.168.1.1	Appends random data to sent packets

Example IDS Evasion command

```
nmap -f -t 0 -n -Pn -data-length 200 -D
192.168.1.101,192.168.1.102,192.168.1.103,192.168.1.23 192.168.1.1
```

Output

Switch	Example	Description
-oN	nmap 192.168.1.1 -oN normal.file	Normal output to the file normal.file
-oX	nmap 192.168.1.1 -oX xml.file	XML output to the file xml.file

-oG	nmap 192.168.1.1 -oG grep.file	Grepable output to the file grep.file
-oA	nmap 192.168.1.1 -oA results	Output in the three major formats at once
-oG -	nmap 192.168.1.1 -oG -	Grepable output to screen. -oN -, -oX - also usable
--append-output	nmap 192.168.1.1 -oN file.file --append-output	Append a scan to a previous scan file
-v	nmap 192.168.1.1 -v	Increase the verbosity level (use -vv or more for greater effect)
-d	nmap 192.168.1.1 -d	Increase debugging level (use -dd or more for greater effect)
--reason	nmap 192.168.1.1 --reason	Display the reason a port is in a particular state, same output as -vv
--open	nmap 192.168.1.1 --open	Only show open (or possibly open) ports
--packet-trace	nmap 192.168.1.1 -T4 --packet-trace	Show all packets sent and received
--iflist	nmap --iflist	Shows the host interfaces and routes
--resume	nmap --resume results.file	Resume a scan

Helpful Nmap Output examples

Command	Description
<code>nmap -p80 -sV -oG - --open 192.168.1.1/24</code>	<code>grep open</code>
<code>nmap -iR 10 -n -oX out.xml</code>	<code>grep "Nmap"</code>
<code>nmap -iR 10 -n -oX out2.xml</code>	<code>grep "Nmap"</code>
<code>ndiff scan1.xml scan2.xml</code>	Compare output from nmap using the ndif
<code>xsltproc nmap.xml -o nmap.html</code>	Convert nmap xml files to html files
<code>grep " open " results.nmap</code>	<code>sed -r 's/ +/ /g'</code>

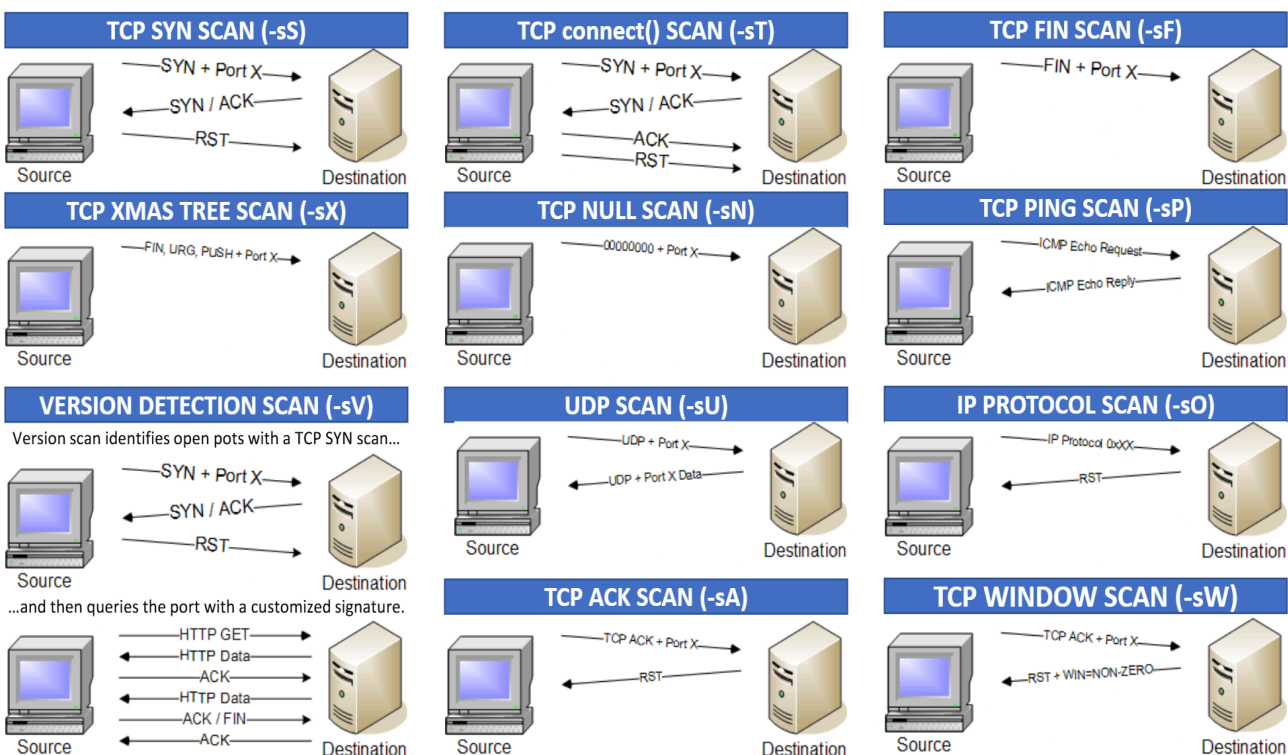
Miscellaneous Options

Switch	Example	Description
-6	<code>nmap -6 2607:f0d0:1002:51::4</code>	Enable IPv6 scanning
-h	<code>nmap -h</code>	nmap help screen

Other Useful Nmap Commands

Command	Description
nmap -iR 10 -PS22-25,80,113,1050,35000 -v -sn	Discovery only on ports x, no port scan
nmap 192.168.1.1-1/24 -PR -sn -vv	Arp discovery only on local network, no port scan
nmap -iR 10 -sn -traceroute	Traceroute to random targets, no port scan
nmap 192.168.1.1-50 -sL --dns-server 192.168.1.1	Query the Internal DNS for hosts, list targets only

Identifying Open Ports with Nmap



Masscan Usage

High-speed port scanning

```
masscan -p1-65535 target --rate=1000          # Full port range at 1000 pps
masscan -p80,443,8080,8443 target --rate=10000 # Specific ports at high speed
masscan --top-ports 100 target --rate=5000      # Top 100 ports scan
```

Output formatting

```
masscan -p1-65535 target --rate=1000 -oG masscan.out # Grepable output
masscan -p1-65535 target --rate=1000 -oJ masscan.json # JSON output
masscan -p1-65535 target --rate=1000 -oX masscan.xml  # XML output
```

PERFORM NETWORKING SCANNING USING AI

1. Scan a Target using ShellGPT

After incorporating the ShellGPT API in Parrot Security Machine, in the terminal window run.

```
sgpt --chat scan --shell "Use hping3 to perform ICMP scanning on the target IP address 10.10.1.11 and stop after 10 iterations"
```

Now to perform ACK scan on target IP address:

```
sgpt --chat scan --shell "Run a hping3 ACK scan on port 80 of target IP 10.10.1.11"
```

To perform host discovery:

```
sgpt --chat scan --shell "Scan the target network 10.10.1.0/24 for active hosts and place only the IP addresses into a file scan1.txt"
```

To perform nmap scan against the IP addresses that were gathered in previous step run:

```
sgpt --chat scan --shell "Run a fast but comprehensive nmap scan against scan1.txt with low verbosity and write the results to scan2.txt"
```

To run ICMP echo scan:

sgpt --chat scan --shell "Use nmap to perform ICMP ECHO ping sweep on the target network 10.10.1.0/24"

Other scans prompts:

- sgpt --chat scan --shell "Perform stealth scan on target IP 10.10.1.11 and display the results"
- sgpt --chat scan --shell "Perform an XMAS scan on target IP 10.10.1.11"
- sgpt --chat scan --shell "Use Nmap to scan for open ports and services against a list of IP addresses in scan1.txt and copy only the port, service and version information with the respective IP address to a new file called scan3.txt"
- sgpt --chat scan --shell "Use Metasploit to discover open ports on the IP address 10.10.1.22"
- sgpt --chat scan --shell "Use Nmap to scan open ports, MAC details, services running on open ports with their versions on target IP 10.10.1.11"
- sgpt --chat scan --shell "Use TTL value and identify the operating system running on the target IP address 10.10.1.11, display the TTL value and OS"
- sgpt --chat scan --shell "Use TTL value and identify the operating system running on the target IP address 10.10.1.9, display the TTL value and OS"
- sgpt --chat scan --shell "Use Nmap script engine to perform OS discovery on the target IP addresses in scan1.txt"
- sgpt --chat scan --shell "Develop a script which will automate network scanning efforts and find out live systems, open ports, running services, service versions, etc. on target IP range 10.10.1.0/24"
- sgpt --chat scan --shell "To evade an IDS/Firewall, use IP address decoy technique to scan the target IP address 10.10.1.22"
- sgpt --chat scan --shell "Within scan1.txt file remove 10.10.1.14 and 10.10.1.13 entries, then display results"
- sgpt --chat scan --code "Create a python script to run a fast but comprehensive Nmap scan on the IP addresses in scan1.txt and then execute vulnerability scanning using nikto against each IP address in scan1.txt"

